

HTTP, HTTPS & TLS Deep Dive

HTTP Fundamentals

HTTP is a request/response text protocol on top of TCP (or QUIC).

Request:

```
GET /login HTTP/1.1
Host: example.com
User-Agent: curl/8.0
Cookie: session=abc123
```

Response:

```
HTTP/1.1 200 OK
Content-Type: text/html
Set-Cookie: session=def456; HttpOnly; Secure
```

Methods & Status Codes You MUST Know

Method	Purpose	Dangerous?
GET	Retrieve	Safe-ish (but leaks data in URL)
POST	Create/submit	Often CSRF target
PUT	Replace	Unsafe (IDOR)
DELETE	Remove	Unsafe
OPTIONS	Explore allowed	Recon
HEAD	Headers only	Recon

Code	Meaning
200	OK
301/302	Redirect
401/403	Auth / Forbidden
404	Not found
500/502/503	Server errors

Headers That Matter for Security

`Content-Security-Policy` (CSP) – blocks XSS

`Strict-Transport-Security` (HSTS) – force HTTPS

`X-Content-Type-Options: nosniff` – stop MIME sniffing

`Set-Cookie: HttpOnly; Secure; SameSite` – hardens cookies

`Referrer-Policy` – stop referrer leakage

Cookies

Cookies are the session token's vehicle. Attack surface:

`Session fixation` – force a known session ID

`Cookie theft` – via XSS (unless `HttpOnly`)

`CSRF` – site A makes your browser send an authenticated request to site B

`HttpOnly` prevents JavaScript reading the cookie and thus blocks the most common XSS→cookie theft chain.

TLS: The Handshake

The HTTPS magic. Simplified handshake:

Client → Server: "ClientHello" (TLS version, cipher suites)

Server → Client: "ServerHello", certificate (with public key), cipher choice

Client verifies certificate (trust chain, hostname, not expired)

Client → Server: key exchange (e.g., ECDHE), "Finished"

Server: "Finished"

Encrypted application data flows

Forward secrecy (ECDHE) means each session uses a fresh ephemeral key – even if the server's long-term key leaks later, past sessions stay secret.

TLS attacks to know: **downgrade** (force older protocol), **MITM with fake cert** (unless cert validation is strong), **heartbleed** (CVE-2014-0160 – memory leak via extension), **CRIME/BREACH** (compression side channels).

[← DNS in Depth & DNS Attacks](#)

[Wireshark & Packet Analysis →](#)